ACTA DE REVISIÓN DEL SGSI POR EL COMITÉ DE SEGURIDAD DE LA INFORMACIÓN

Ámbito de difusión	USO OFICIAL INTERNO RESTRINGIDO
Responsable	RESPONSABLE DEL SGSI

REGISTRO DE FIRMAS		
Función:	**Elaborado por:**	**Aprobado por:**
Departamento:	Secretario del comité de seguridad	Jefe del comité de seguridad
Nombre:	David Pozo	Carlos Rodrigo
Firma:	Firmado por POZO SANCHEZ DAVID - ***6992** el día 17/04/2025	Firmado por RODRIGO RIVERO, CARLOS (AUTENTICACIÓN) el día 17/04/2025 con un certificado emitido por AC
Fecha:	17/04/2025	17/04/2025

CONTENIDO

1 INTRODUCCIÓN 4
1.1 FECHA Y LUGAR DE REUNIÓN 4
1.2 OBJETO 4
2 ENTRADAS DE LA REVISIÓN DEL SISTEMA 4
2.1 ESTADO DE LAS ACCIONES DE ANTERIORES REVISIONES POR LA DIRECCIÓN 4
2.2 CAMBIO EN LAS CUESTIONES INTERNAS Y EXTERNAS PERTINENTES AL SGSI 4
2.3 CAMBIOS EN LAS NECESIDADES Y EXPECTATIVAS DE LAS PARTES INTERESADAS 5
2.4 INFORMACIÓN Y TENDENCIAS SOBRE EL COMPORTAMIENTO DE LA SEGURIDAD DE LA INFORMACIÓN 5
2.4.1 No conformidades y acciones correctivas 5
2.4.2 Seguimiento y resultados de las mediciones 5
2.4.3 Resultado de auditorías 6
2.4.4 Cumplimiento de los objetivos de seguridad de la información 6
2.5 COMENTARIOS PROVENIENTES DE LAS PARTES INTERESADAS 6
2.6 RESULTADOS DE LA EVALUACIÓN DE RIESGOS Y ESTADO DEL PLAN DE TRATAMIENTO DE RIEGOS 6
2.7 OPORTUNIDADES DE MEJORA CONTINUA 7
2.8 REVISIÓN DE LA POLÍTICA DE SEGURIDAD DE LA INFORMACIÓN 7
3 salidas a la revisión del sistema 7
3.1 NECESIDADES DE RECURSOS 7
3.2 CAMBIOS EN EL SISTEMA O EN LOS SERVICIOS 7
3.3 CONCLUSIONES 7

1 INTRODUCCIÓN

1.1 FECHA Y LUGAR DE REUNIÓN

En Teams, a 16 de abril, de 2025, a las 10:00

Carácter de la reunión: Ordinaria.

Asistentes:

- Carlos Zúñiga: CEO
- Carlos Rodrigo: CIO
- Fernando Pozo: COO
- José Martín: CCI
- Vicente Gallego: CSO
- Jaime de Castro: CTO
- Iván Pérez: Director de calidad
- David Pozo: Responsable del SGSI

ID de la revisión: REV_SGSI_01

1.2 OBJETO

Con la finalidad de asegurar que se mantiene constantemente la conveniencia adecuación y eficacia de los criterios y procedimientos marcados el comité de seguridad de la información de Spika Tech realiza anualmente una revisión del funcionamiento del sistema de gestión de seguridad de la información.

Esta revisión permite evaluar las oportunidades de mejora y la necesidad de efectuar cambios en el sistema de gestión, incluyendo la política, los riesgos y los objetivos.

La revisión ordinaria anual del SGSI se realiza siempre con posterioridad a la realización de la auditoría interna del sistema.

2 ENTRADAS DE LA REVISIÓN DEL SISTEMA

2.1 ESTADO DE LAS ACCIONES DE ANTERIORES REVISIONES POR LA DIRECCIÓN

No existen acciones anteriores debido a que esta es la primera revisión.

2.2 CAMBIO EN LAS CUESTIONES INTERNAS Y EXTERNAS PERTINENTES AL SGSI

Debido a que es la primera revisión del SGSI, no ha habido cambios, pero si que ha quedado todo registrado en el SharePoint interno de Spika Tech, en el apartado correspondiente.

Todas las cuestiones internas y externas del SGSI están registras en dicho SharePoint.

2.3 CAMBIOS EN LAS NECESIDADES Y EXPECTATIVAS DE LAS PARTES INTERESADAS

- **Registro de horas**: Necesidad de un sistema de registro de horas en el que se pueda especificar en que proyecto has invertido las horas y si han sido presencial o en remoto.
- **Sistema de tickets**: Mejoras en el sistema de tickets para que llegue notificaciones y cada usuario solo pueda ver sus solicitudes.
- **Formularios**: Traspasar los formularios existentes en Microsoft Forms a Jira para unificar herramientas.
- **Desarrollo seguro**: Integrar el desarrollo seguro en el día a día de la empresa siguiendo lo establecido en el SGSI.
- **Control de acceso**: Mejorar el control de acceso y registro de quien accede tanto a activos físicos como digitales.
- **Ubicación SGSI**: Migrar el SGSI a una web interna de Spika Tech para que sea más fácil y ágil acceder a ella.

2.4 INFORMACIÓN Y TENDENCIAS SOBRE EL COMPORTAMIENTO DE LA SEGURIDAD DE LA INFORMACIÓN

2.4.1 No conformidades y acciones correctivas

Debido a que esta es la primera revisión y a la reciente implementación del SGSI y de la ISO 27001, el número de no conformidades ha sido elevada. Todas han sido solventadas (a la espera de la fase 2 de la auditoría externa), y han quedado registradas en detalle en el Excel "**Plan_de_Acciones_Correctivas_ISO27001**", el cual se encuentra en el SGSI.

A modo de resumen, dejo aquí los controles afectados, para más detalles revisar el Excel:

4.2, 4.3, 4.4, 5.1, 5.2, 5.3, 6.1, 6.1.1, 6.2, 6.3, 7.1, 7.2, 7.4, 8.1, 8.3, 9.1, 9.2, 9.3, 10.1, 10.2

ANEXO A - 5.1, ANEXO A - 5.3, ANEXO A - 5.6, ANEXO A - 5.7, ANEXO A - 5.15, ANEXO A - 5.16, ANEXO A - 5.17, ANEXO A - 5.25, ANEXO A - 5.26, ANEXO A - 5.28, ANEXO A - 5.36, ANEXO A - 6.1, ANEXO A - 6.3, ANEXO A - 7.1, ANEXO A - 7.2, ANEXO A - 7.10, ANEXO A - 7.12, ANEXO A - 8.6, ANEXO A - 8.8, ANEXO A - 8.13, ANEXO A - 8.15, ANEXO A - 8.16, ANEXO A - 8.17, ANEXO A - 8.18, ANEXO A - 8.19, ANEXO A - 8.20, ANEXO A - 8.22, ANEXO A - 8.29, ANEXO A - 8.34

2.4.2 Seguimiento y resultados de las mediciones

Por un lado, los incidentes de seguridad han sido menores, y todos han sido reportados y mitigados con rapidez y éxito.

Debido a la reciente implementación del SGSI y de la ISO 27001, solo ha habido 1 incidente, en este caso, un intento de phishing, el cual fue detectado a tiempo y no hubo ningún activo afectado.

Todos los incidentes que ocurran quedan registrados en el Excel "RGS_3 Indicadores Seguridad V.01", el cual se localiza en el SGSI.

2.4.3 Resultado de auditorías

A fecha de la realización de esta acta, se ha realizado 1 auditoría interna por parte de Cyberxia en Marzo de 2025, y la primera fase de la auditoría externa por parte de AENOR en Marzo de 2025.

- **Auditoría interna**: En la auditoría interna se detectaron 4 no conformidades mayores, 29 no conformidades menores, 11 observaciones y 1 oportunidad de mejora.
  Esta auditoría se realizó a modo de preparación para la auditoría externa.
  Hablando con los auditores, bajo su criterio si que pasamos la auditoría.
- **Auditoría externa (fase 1)**: En la auditoría externa (fase 1), se detectaron 10 observaciones. El auditor aclaró que en la fase 1 nunca pone no conformidades, aunque las haya.
  Durante la fase 1 de la auditoría solo se revisaron los controles relativos a la ISO 27001, no se revisaron los del ANEXO A que hacen referencia a la ISO 27002.

Prácticamente todas las no conformidades (de ambas auditorías) han sido solventadas a día de hoy, 16/04/2025.

2.4.4 Cumplimiento de los objetivos de seguridad de la información

Durante la implementación de la ISO 27001, se ha realizado un análisis de riesgos con su correspondiente PTR, donde se puede observar que se han solventado más del 95% de los riesgos encontrados.

Por otro lado, se han resuelto más del 95% de las no conformidades encontradas en ambas auditorías. Todas las no conformidades han quedado reflejadas en el plan de acciones.

Desde la implementación de la ISO 27001 no ha habido ningún ataque exitoso contra Spika Tech, por lo que las medidas tomadas durante dicha implementación están siendo fructíferas.

2.5 COMENTARIOS PROVENIENTES DE LAS PARTES INTERESADAS

Los únicos comentarios recibidos del SGSI han sido por parte de los empleados de la empresa. Estos comentarios en un inicio fueron de dudas debido a que ha sido algo nuevo a lo que la empresa no estaba acostumbrada, pero durante la implementación los empleados se fueron acostumbrando y han empezado a aplicar las medidas que se describen en el SGSI, aunque como se ha comentado anteriormente en este documento, aún falta tiempo para que esté 100% integrado en la empresa.

2.6 RESULTADOS DE LA EVALUACIÓN DE RIESGOS Y ESTADO DEL PLAN DE TRATAMIENTO DE RIEGOS

Al inicio de la implementación de la ISO 27001 y del SGSI, se realizó un análisis de riesgos con la ayuda de Cyberxia. En este análisis de riesgos se detectaron numerosos riesgos debido a que hasta ese momento la empresa no se había centrado en la seguridad.

Todos estos riesgos quedaron registrados tanto en un documento, como en un Excel, donde se clasificaban según su naturaleza y a que activos afectaba, aparte de ponerle un nivel de criticidad basado en la probabilidad de que ocurra y en el impacto que tendría si ocurre.

Una vez localizados y categorizados, los de nivel mayor y críticos fueron analizados y listados en el PTR, para su resolución.

A día de hoy, se solo quedan 2 por resolver (1 mayor y otro crítico), por lo que más del 95% de los riesgos detectados han sido mitigados.

Para más detalle revisar el Excel del PTR "PTR AARR_SPIKA TECH_2025".

2.7 OPORTUNIDADES DE MEJORA CONTINUA

Durante los últimos meses se ha trabajado mucho en desarrollar y mejorar el SGSI, y a día de hoy está muy completo, pero a falta de la fase 2 de la auditoría externa, hay algunos aspectos que se pueden mejorar a pesar de que ya funcionan y cumplen su función:

- **Registro de horas**: Mejorar el sistema de registro de horas, debido a que actualmente solo registra la hora de entrada, salido y de descanso. Este sistema debe mejorar para poder registrar si el trabajo es presencial o remoto.
- **Concienciación**: Durante los últimos meses se ha impartido una serie de cursos para ampliar el conocimiento de los empleados, pero es necesario que sigan aprendiendo. Para ello se ha desarrollado el plan anual de formación.

2.8 REVISIÓN DE LA POLÍTICA DE SEGURIDAD DE LA INFORMACIÓN

La política ha sido revisada y permanece vigente. Se ha actualizado para incorporar referencias al cambio climático, en respuesta a una no conformidad detectada.

Esta política se encuentra disponible en la página web de la organización.

3 SALIDAS A LA REVISIÓN DEL SISTEMA

3.1 NECESIDADES DE RECURSOS

Actualmente ya se ha realizado la inversión necesaria para implementar el SGSI y lo relacionado con ella. Aún así, se a desarrollado una planificación de gastos y de recursos anual, junto con un plan de capacidad para saber que se va a necesitar y los recursos que ello conlleva.

Estas planificaciones están disponibles en el SGSI.

3.2 CAMBIOS EN EL SISTEMA O EN LOS SERVICIOS

A día de hoy, el SGSI ha sido actualizado con todos los requisitos de la ISO 27001, requisitos de la empresa y no conformidades de las auditorías, por lo que no hay cambios planeados más allá de los definidos anteriormente en el apartado 2.3 y 2.7.

Después de la fase 2 de la auditoría, en caso de que se detecten no conformidades, habrá que cambiar el SGSI para adaptarlo a dichas no conformidades.

3.3 CONCLUSIONES

Tras la revisión detallada de los puntos presentados y el análisis de los resultados obtenidos durante el proceso de implementación y mantenimiento del Sistema de Gestión de Seguridad de la Información (SGSI), el Comité de Seguridad concluye que:

- El SGSI de Spika Tech ha sido correctamente implantado, y se encuentra actualmente en una fase de madurez temprana, pero sólida, habiéndose integrado de manera funcional en la operativa diaria de la organización.
- Se ha demostrado un **alto grado de compromiso por parte del personal y los responsables**, tanto en el cumplimiento de las acciones derivadas de auditorías como en la ejecución del Plan de Tratamiento de Riesgos.
- A pesar del elevado número de no conformidades inicialmente detectadas (propio de una primera implementación), se ha alcanzado un **índice de resolución superior al 95%**, lo cual refleja una correcta capacidad de reacción, adaptación y mejora.
- El comportamiento del sistema en términos de indicadores ha sido positivo, con un **único incidente de seguridad** registrado y resuelto satisfactoriamente, lo que refuerza la eficacia de los controles implementados.
- El cumplimiento de los **objetivos de seguridad de la información** definidos se encuentra bien encaminado, con un tratamiento adecuado de riesgos, una política de seguridad vigente y actualizada, y acciones formativas en marcha.
- Se identifican **oportunidades de mejora** centradas principalmente en aspectos operativos, como el registro de horas, la concienciación continua y la migración del SGSI a una plataforma más accesible, que serán abordadas en los próximos meses como parte del ciclo de mejora continua.
- No se identifican en esta fase necesidades críticas adicionales de recursos, aunque se mantiene una planificación dinámica para dar soporte al crecimiento del SGSI y responder a futuras necesidades detectadas tras la auditoría externa definitiva.

En resumen, el Comité considera que el SGSI se encuentra **en estado eficaz y operativo**, preparado para afrontar la **fase 2 de la auditoría externa** y con una base sólida para avanzar hacia su consolidación y mejora continua dentro de la organización.

Se cierra esta revisión por parte del Comité de Seguridad de la información a las 12:48

Para que conste, firman el secretario del comité de seguridad y el presidente del comité de seguridad al inicio del documento.